Jr.Pen 9.3.Vulnerability Identification Techniques

Task 1 - Introduction

Vulnerability identification is the process of examining a target environment to identify exploitable weaknesses. These weaknesses can occur in network services, operating systems, or applications. Before you can exploit anything, you need to know what is there and what is wrong with it.

This phase is distinct from both reconnaissance and exploitation. Reconnaissance is about collecting information about the target, such as IP ranges, domain names, and publicly exposed infrastructure. Exploitation is the act of leveraging a confirmed weakness to achieve a specific outcome. Vulnerability identification sits between the two.



An attacker who skips straight from a port scan to running an exploit is guessing. Without knowing what software a target is running, how it is configured, and what version it is at, there is no rational basis for choosing an attack path. A methodical approach to vulnerability identification removes that guesswork and gives you a clear picture of where a target is weak before you commit to an exploitation strategy.

The techniques covered here follow that methodology from start to finish. You will begin by mapping the attack surface of a target environment, then enumerate services and extract version information. From there, you will cross-reference those versions against public vulnerability databases, probe a web application for common flaw classes, and test system-level services for misconfigurations. A

practical challenge at the end brings all of these techniques together against a single machine.

Task 2 - Understanding the Attack Surface

The attack surface of a system is the total set of points where an attacker can attempt to interact with it. Every open port, running service, input field, and API endpoint is part of that surface. The larger and more varied it is, the more likely it is that something has been misconfigured, left unpatched, or otherwise exposed.

An attack surface spans network ports and protocols, operating system configurations and permissions, and application-level input mechanisms.



External attack surfaces represent perimeter entry points reachable from outside, while internal surfaces expose high-value, often under-secured assets reachable only after gaining an initial foothold.

Answer the questions below

> Which type of attack surface becomes accessible only after gaining an initial foothold inside the network?

Internal

Task 3 - Service Enumeration and Banner Grabbing

Port Scanning with Nmap:

```
nmap -sV -sC -p- MACHINE_IP -oN scan_results
```

The `-sV` flag enables version detection. Rather than just reporting that port 22 is open, Nmap probes the service and tries to determine the software and its version. The `-sC` flag runs Nmap's default scripts, which perform extra checks such as testing for anonymous FTP access or retrieving HTTP page titles. The `-p-` flag scans all 65,535 TCP ports rather than just the default set. The `-oN` flag saves the output of the scan to a file named scan_results.

Banner Grabbing:

```
nc MACHINE_IP 22
```

That single string reveals the OpenSSH version and the underlying operating system. It is enough to start searching for known vulnerabilities against that version.

Netcat (`nc`) is a raw data pipeline for reading and writing network connections, while **Nmap** is an automated discovery engine built to map entire networks and audit security.

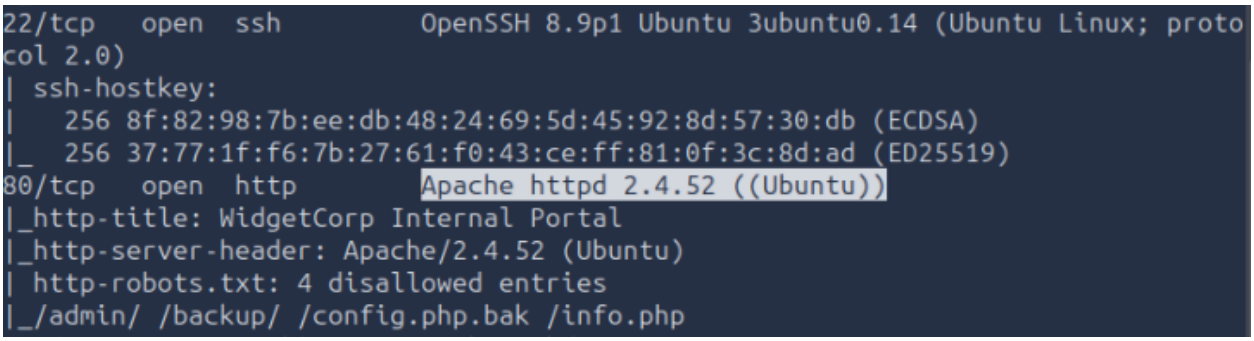
Feature	Netcat (nc)	Nmap
Primary Purpose	Establishing direct TCP/UDP connections, transferring files, binding shells, or debugging single endpoints.	Discovering active hosts, open ports, running OS versions, and vulnerabilities across network ranges.
Scope	Point-to-point (one connection or port at a time).	Mass scanning across large IP blocks (thousands of ports simultaneously).
Scanning Technique	Performs full standard TCP connections (`connect()`). Slow and noisy for scanning multiple ports.	Uses raw packets (SYN stealth scans, UDP probes, FIN/Xmas scans) to analyze responses at the packet level.
Data Handling	Moves raw input/output (stdin/stdout) directly across sockets.	Analyzes protocol signatures, banners, and script responses without acting as an interactive pipe.
Key Use Cases	Banner grabbing, simple TCP/UDP listeners, manual testing, port	Network inventory, OS fingerprinting, vulnerability

	forwarding, basic chat/file transfer.	detection (via Nmap Scripting Engine / NSE).

Answer the questions below

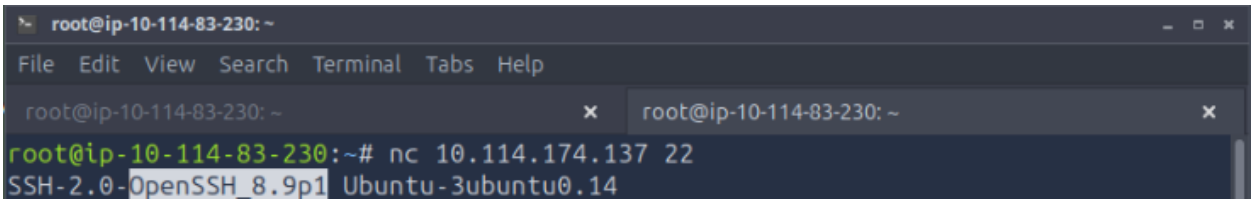
> Run an Nmap scan against the target with -sV -sC flags. What version of Apache is running on port 80?

2.4.52



> Use netcat to grab the SSH banner on port 22. What is the full OpenSSH version string returned?

OpenSSH_8.9p1



Task 4 - Matching Services to Known Exploits

A typical workflow after enumeration:

1. Take the first service and version from your inventory.
2. Search the NVD or Exploit-DB for that software name and version.
3. Check GitHub for the CVE identifier to find any proof-of-concept code or tooling.

4. Review the results, noting any CVEs affecting the exact version or a range that includes it.
5. Assess each result for relevance and exploitability.
6. Repeat for every service in the inventory.

CVSS severity ratings measure theoretical impact, but practical value depends on real-world accessibility and the attack path provided.

A vulnerability is only truly exploitable when active software configurations, network controls, patch states, and access prerequisites line up to allow execution.



Automated Vulnerability Scanners

Tools such as Nessus, OpenVAS, and Nikto automate the process of matching services against vulnerability databases. They run their own enumeration and compare results against known issues, producing a report of potential vulnerabilities.

These scanners are useful for covering a broad attack surface quickly. However, they produce false positives and miss issues that require contextual understanding, things like business logic flaws or chained weaknesses that only work in combination. Scanner output is a starting point for manual investigation, not a replacement for it.

Answer the questions below

> A CVE describes a remote code execution flaw in the version of a service running on the target, but the administrator has applied a patch without updating the version string. Is this service still exploitable through that CVE?

Nay

Task 5 - Identifying Web Application Vulnerabilities

Establishing a normal baseline of application behavior through passive navigation and proxy logging is essential for detecting abnormal responses when probing for web application vulnerabilities.

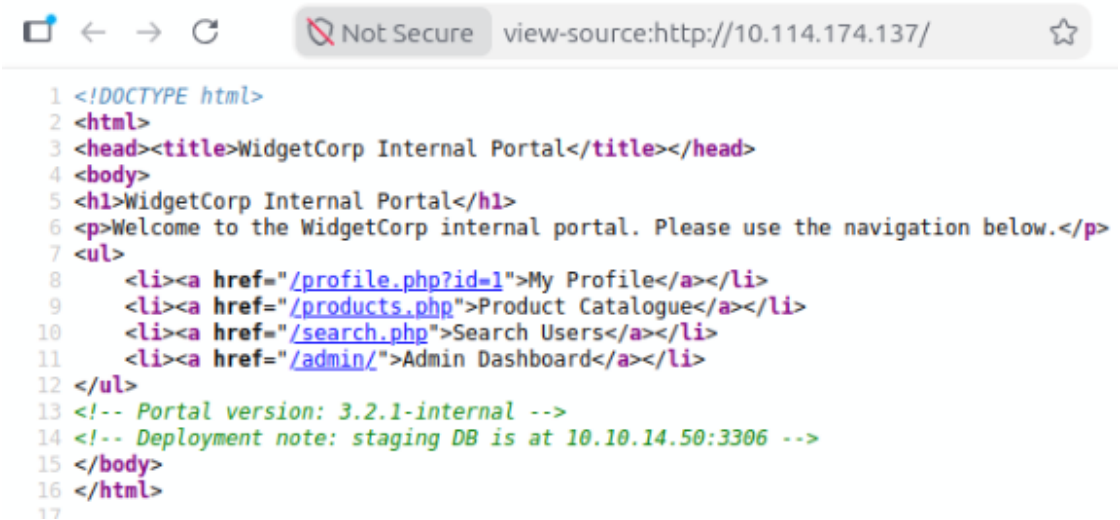
Access control vulnerabilities (such as IDOR and vertical privilege escalation) occur when applications fail to enforce authorization checks on object references or administrative endpoints.

Information disclosure exposes sensitive technical details, system paths, or credentials through response headers, detailed error messages, and accessible backup files, providing critical insights for subsequent attacks.

Answer the questions below

> Navigate to http://10.114.174.137 in your browser and view the HTML source of the main page. What internal IP address is referenced in the deployment note comment?

10.10.14.50



> Access /profile.php?id=1, then change the id parameter to 2. You can view another user's profile without authorisation. What type of vulnerability is this?

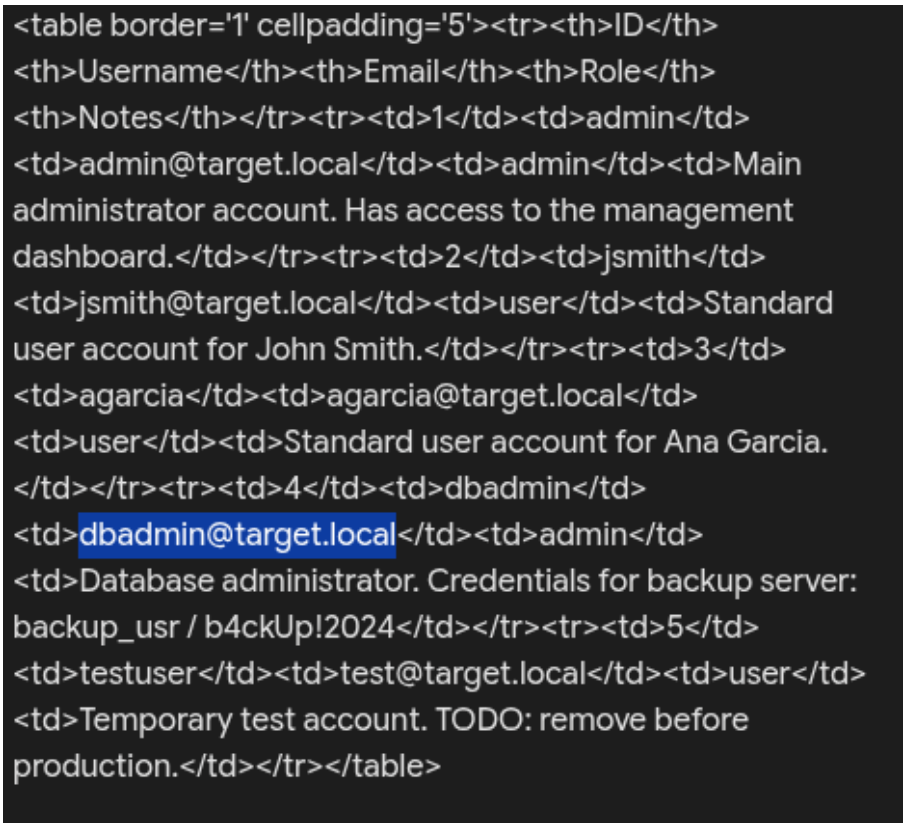
IDOR

This is an **Insecure Direct Object Reference (IDOR)** vulnerability. IDOR is a type of access control vulnerability that occurs when an application uses user-supplied input to access objects (like user profiles, files, or database records) directly without properly validating if the requesting user is authorized to view or modify that specific resource.

> Navigate to /admin/. What is the username of the user whose notes contain backup server credentials?

dbadmin

User ID 4



Task 6 - Identifying System and Network Vulnerabilities

Default and Weak Credentials:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://MACH
INE_IP
```

Take care with account lockout policies and rate limiting. Aggressive brute-force attempts can lock out accounts or trigger alerts. At the identification stage, you are trying to determine whether weak credentials are likely, not trying every possible combination.

SMB Misconfigurations:

The Server Message Block (SMB) protocol is used widely in Windows environments for file sharing and inter-process communication. Misconfigurations are common. (It anonymously lists all available Server Message Block (SMB) shares on a target machine.)

```
smbclient -L //MACHINE_IP -N
```

The `-N` flag suppresses the password prompt. If the target returns a share list, you have unauthenticated access to at least the listing. From there, try connecting to each share and check whether any allow read or write access without credentials.

```
nmap --script smb2-security-mode -p 445 MACHINE_IP
```

If the output shows that message signing is enabled but not required, the service is vulnerable to relay.

FTP Misconfigurations:

FTP is an older file transfer protocol still found in many environments, especially on legacy systems. The most common misconfiguration is anonymous access: (This command uses `ftp` to establish a File Transfer Protocol (FTP) connection to a remote target host (`MACHINE_IP`) over port 21 by default.)

```
ftp MACHINE_IP
Name: anonymous
Password: anything@here.com
```

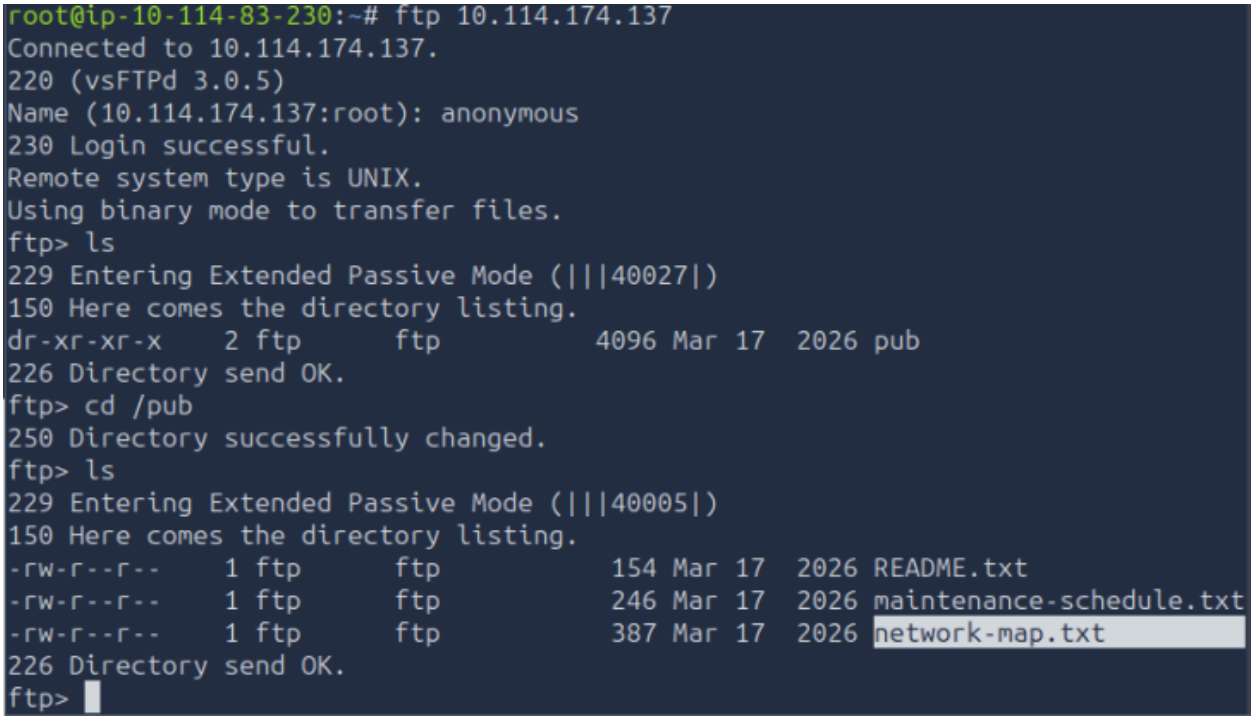
If the server accepts the connection, look through the directory listing for sensitive files. FTP servers with anonymous access sometimes expose configuration files,

backups, or credentials. Even if the files are not directly exploitable, the presence of an anonymous FTP server is worth noting.

Answer the questions below

> Connect to the FTP service using anonymous access. What is the filename in the /pub directory that contains the internal network map?

network-map.txt



> According to the file, what are the default credentials for the Dev environment? (Format: username:password)

devops:D3vOps2024!

```
root@ip-10-114-83-230:~# ftp 10.114.174.137
```

```
ftp> ls
229 Entering Extended Passive Mode (|||40005|)
150 Here comes the directory listing.
-rw-r--r--    1 ftp      ftp           154 Mar 17  2026 README
```

```
E.txt
-rw-r--r--    1 ftp      ftp           246 Mar 17  2026 maint
enance-schedule.txt
-rw-r--r--    1 ftp      ftp           387 Mar 17  2026 netwo
rk-map.txt
```

ftp> get network-map.txt then exit

```
root@ip-10-114-83-230:~# cat network-map.txt
WidgetCorp Internal Network Map (Q3 2024)
========================================
Web Server:       10.10.14.10 (this machine)
Database Server:  10.10.14.50 (MariaDB, PostgreSQL)
Domain Controller: 10.10.14.1 (dc01.widgetcorp.local)
Backup Server:    10.10.14.60 (rsync, SSH)
Dev Environment:  10.10.14.100 (Docker host)

Default credentials for dev environment: devops / D3vOps2024!
```

> Use smbclient to list shares on the target with a null session. What is the name of the readable share?

shared

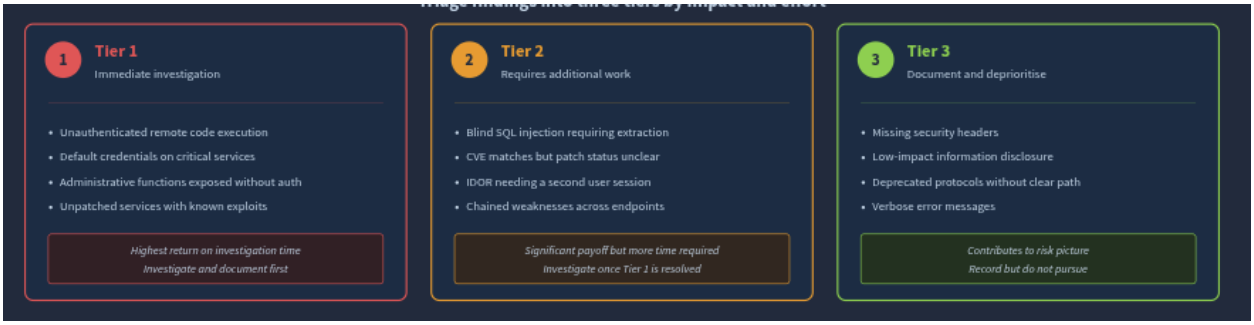
```
root@ip-10-114-83-230:~# smbclient -L //10.114.174.137 -N

        Sharename       Type      Comment
        ---------       ----      -------
        shared          Disk      Internal shared documents
        IPC$            IPC       IPC Service (WidgetCorp File Server)
SMB1 disabled -- no workgroup available
```

Task 7 - Triaging and Documenting Findings

Vulnerability impact is determined by the depth of access gained, sensitivity of exposed data, and the systemic importance of the compromised machine within the network.

Sorting findings into three tiered categories based on effort and potential access prioritizes high-impact entry points over low-risk issues, maximizing testing efficiency.



Detailed documentation recorded in real time with explicit evidence, step-by-step reproduction instructions, and clear impact assessments is crucial for unambiguous finding verification.

Answer the questions below

> You discover an unauthenticated remote code execution vulnerability on an externally facing web server. Which priority tier does this belong to?

1

> You find that a service is using a deprecated protocol but cannot identify a clear exploitation path. Which priority tier does this belong to?

3

Task 8 - Practical Challenge

Work through the target machine using the techniques from the previous tasks. Your goal is to enumerate the attack surface, identify the vulnerabilities planted on the machine, and answer the questions below.

The questions cover three areas:

1. A web application flaw found through manual probing
2. An FTP misconfiguration found through direct interaction with the service
3. An SMB share misconfiguration found through direct interaction with the service

For the web application flaw, examine how the application handles user input in URL parameters and check whether access controls are consistent across all endpoints. For the FTP and SMB misconfigurations, test every service that

supports authentication for default credentials and anonymous access, and read any files you can access for sensitive information.

Answer the questions below

> What URL path exposes the admin dashboard without any authentication?

admin

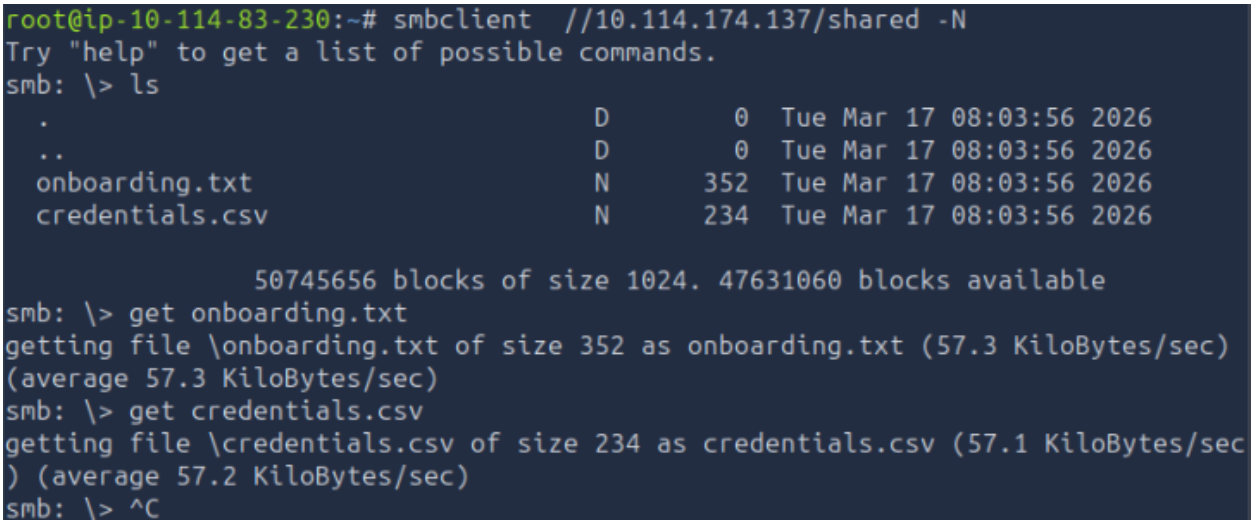
> What file on the anonymous FTP server reveals that several servers are 3+ months behind on patches?

maintenance-schedule.txt

> What is the default temporary password assigned to new employees according to the SMB share's onboarding document?

Welcome2024!

```
root@ip-10-114-83-230:~# smbclient  //10.114.174.137/shared -N
```



```
root@ip-10-114-83-230:~# ls
CTFBuilder              credentials.csv           scan_results
Desktop                 curl                      snap
Documents               full-suite.txt            test-reports
Downloads               full-suite2.txt           theHarvester-wrapper.orig
Pictures                go                        tools-final.log
Postman                 hydra.restore             tools-postboot.log
README.txt              install-th2.log           tools-run.log
Rooms                   maintenance-schedule.txt  tools-run2.log
Scripts                 msf-login.txt             tools-run3.log
Templates               neoreg_servers            zap-gui-cat.txt
arm1-uncontained.txt    network-map.txt           zapfix-fresh.txt
arm2-contained.txt      onboarding.txt            zapfix-restored.txt
arm2b-contained.txt     reports
root@ip-10-114-83-230:~# cat onboarding.txt
New Employee Onboarding - IT Checklist
=====================================
1. Create AD account (request via ServiceNow)
2. Assign to "Domain Users" group
3. Set temporary password: Welcome2024!
   (User must change on first login)
4. Provision laptop from imaging server (10.10.14.70)
5. Enrol in MFA (postponed until Q2 - budget approval pending)
```

Task 9 - Conclusion

This room covered foundational techniques for identifying vulnerabilities during an offensive security engagement. You mapped attack surfaces, enumerated services and extracted version information, cross-referenced versions against public vulnerability databases, probed web applications for common flaw classes, and inspected system-level services for misconfigurations. You also learned how to triage findings by impact and document them clearly.

The techniques here are deliberately fundamental. They represent the minimum competency required to approach a target environment methodically. Vulnerability identification is a collection of habits: thorough enumeration, careful observation, systematic cross-referencing, and disciplined documentation. The difference between an effective tester and an ineffective one is rarely the tools. It is how methodically they work through the target and how carefully they interpret what they find.

From here, the natural progression is exploitation. Once you can reliably identify that a vulnerability exists, the next step is to confirm it by leveraging it for access or escalation. Rooms covering SQL Injection, SMB relay attacks, and known CVE exploits build directly on the identification skills practised here.

You should also consider deepening your enumeration capabilities. More advanced service enumeration, Active Directory enumeration, and application-layer fuzzing each warrant dedicated study. The better your enumeration, the more complete your vulnerability identification, and the more successful your exploitation attempts will be.